

Threat Intelligence & IOC — Analisi Cattura di Rete

File analizzato: Cattura_U3_W1_L5.pcapng

1. Sintesi esecutiva

L'analisi della cattura di rete evidenzia una scansione di porte TCP (port scan) massiva e automatizzata condotta dall'host 192.168.200.100 nei confronti dell'host 192.168.200.150. Si tratta della fase di ricognizione (Reconnaissance / Scanning) di un potenziale attacco: nessun payload di exploitation è presente nella cattura, ma sono state individuate 12 porte aperte sul target, corrispondenti a servizi legacy e potenzialmente vulnerabili.

2. Dati identificativi degli host

Ruolo	Dettagli
Host sorgente (scanner)	IP: 192.168.200.100 — MAC: 08:00:27:39:7d:fe
Host destinazione (target)	IP: 192.168.200.150 — MAC: 08:00:27:fd:87:1e
Nota	Entrambe le MAC hanno OUI 08:00:27 (VirtualBox) → ambiente di laboratorio virtualizzato

3. IOC identificati — evidenze di attacco in corso

3.1 Port scan TCP massivo

- 1026 pacchetti SYN inviati da .100 verso .150, su 1024 porte di destinazione distinte (range 1–1024).
- Finestra temporale dello scan: circa 13 secondi (09:59:23.658 → 09:59:36.772 UTC, 09/08/2022).
- Velocità: circa 78 pacchetti al secondo — ritmo non riconducibile a un utente umano, ma a un tool automatico.
- 991 porte sorgente effimere differenti utilizzate in rapida sequenza.
- Risposte del target: 1013 pacchetti RST/ACK (porte chiuse) e 13 pacchetti SYN/ACK (porte aperte).
- Nessun payload applicativo in alcun pacchetto: la cattura documenta esclusivamente l'attività di ricognizione.

3.2 Dettaglio tecnico dello scan

Le due sonde iniziali verso le porte 80 e 443 completano l'handshake TCP a tre vie (SYN → SYN/ACK → ACK → RST), mentre tutte le altre porte chiuse ricevono un RST/ACK immediato dopo il SYN. Questo comportamento è coerente con un TCP Connect Scan (ad es. «`snmap -sT`»), tipicamente usato quando lo strumento di scansione opera senza privilegi di root/amministratore.

Prima di ogni raffica di scansione sono presenti richieste ARP tra i due host per la risoluzione degli indirizzi MAC, coerenti con l'avvio di una nuova sessione di scansione verso lo stesso segmento di rete.

3.3 Porte aperte rilevate su 192.168.200.150

Porta	Servizio
21	FTP

Porta	Servizio
22	SSH
23	Telnet
25	SMTP
53	DNS
80	HTTP
111	rpcbind
139	NetBIOS-SSN
445	SMB (Microsoft-DS)
512	exec (r-services)
513	login (rlogin)
514	shell (rsh)

Questa combinazione di porte (FTP, Telnet, rpcbind, NetBIOS/SMB, servizi «r» in chiaro come rlogin/rsh/rexec) e' la firma tipica di un host volutamente vulnerabile (ad es. Metasploitable2): servizi legacy, non cifrati, spesso con versioni vulnerabili o credenziali deboli/di default.

3.4 Traffico secondario non correlato

- Un datagramma broadcast NBNS/SMB (UDP/138) da 192.168.200.150 verso 192.168.200.255 all'inizio della cattura: si tratta di normale rumore di rete Windows/Samba, non un IOC.

4. Ipotesi sul vettore di attacco

Il traffico osservato corrisponde alla fase di Reconnaissance/Scanning della Cyber Kill Chain: l'attaccante sta enumerando i servizi esposti dal target per individuare il vettore di intrusione piu' promettente. Non essendo presente alcun payload applicativo, l'exploit vero e proprio non e' ancora documentato in questa cattura; tuttavia le porte aperte suggeriscono i vettori piu' probabili per la fase successiva dell'attacco:

- FTP (21) → possibili versioni vulnerabili con backdoor note (es. vsftpd 2.3.4).
- Telnet (23) e r-services (512/513/514) → autenticazione in chiaro, credenziali deboli o relazioni di trust abusabili.
- SMB/NetBIOS (139/445) → possibili exploit SMB (es. EternalBlue, Samba usermap script).
- rpcbind (111) → enumerazione di servizi RPC/NFS.
- SSH (22) → possibile tentativo di brute-force delle credenziali nella fase successiva.

5. Azioni consigliate

5.1 Per mitigare l'attacco in corso

- Isolare/bloccare immediatamente l'host sorgente 192.168.200.100 a livello di firewall/switch (ACL o port-block).
- Verificare se lo scan e' un'attivita' autorizzata (pentest pianificato) oppure proviene da un host compromesso interno.

- Attivare un IDS/IPS (es. Suricata/Snort) con regola di rilevamento port-scan (soglia: N pacchetti SYN su porte distinte in T secondi) per generare alert in tempo reale.

5.2 Per ridurre la superficie d'attacco sul target

- Disabilitare o rimuovere i servizi legacy non necessari: Telnet, rsh/rlogin/rexec, FTP anonimo, rpcbind/NFS se non richiesti.
- Sostituire i protocolli in chiaro con equivalenti cifrati (SSH al posto di Telnet/rlogin, SFTP/FTPS al posto di FTP).
- Applicare patch aggiornate a tutti i servizi esposti e verificare l'assenza di credenziali di default.

5.3 Per prevenire attacchi futuri simili

- Segmentare la rete (VLAN/firewall interni) per impedire scansioni e movimento laterale da host non autorizzati.
- Implementare una baseline di hardening (es. CIS Benchmark) e vulnerability scanning periodico.
- Integrare l'IOC (IP sorgente, pattern temporale, elenco porte) in una piattaforma di Threat Intelligence/SIEM per correlare futuri tentativi simili.
- Impostare rate-limiting/connection throttling sui servizi esposti per rallentare eventuali scansioni future.

6. Conclusioni

La cattura documenta in modo inequivocabile un IOC di scansione di rete: 1026 tentativi di connessione TCP su 1024 porte in circa 13 secondi da un singolo host verso un singolo target, con individuazione di 12 servizi attivi ad alto rischio. Si raccomanda di trattare l'evento come precursore di un potenziale attacco di exploitation e di intervenire sia sull'host sorgente (contenimento) sia sul target (hardening) secondo le azioni indicate sopra.